

Chapitre 12

La gestion du risque tiers — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — Le périmètre du risque tiers et son statut taxonomique

- (a) La chaîne à trois niveaux se représente ainsi : l'établissement contracte directement avec le **tiers** ; ce tiers sous-traite à son tour une partie de son activité à une **quatrième partie**, avec laquelle l'établissement n'a aucun lien contractuel ; cette quatrième partie peut elle-même sous-traiter à une **cinquième partie**, plus éloignée encore. L'établissement reste exposé à chacun de ces niveaux car le risque en cause — une défaillance opérationnelle, une fuite de données, une interruption de service — porte sur l'activité elle-même et sur les données ou processus qui y sont associés, non sur l'existence d'un lien contractuel : si la cinquième partie subit une défaillance qui compromet les données ou le service finalement délivré à l'établissement, ce dernier en subit les conséquences (réglementaires, réputationnelles, opérationnelles) exactement comme si la défaillance était survenue chez le tiers direct, quand bien même aucune clause contractuelle ne le relie à cette cinquième partie. Le fondement de l'exposition est ainsi la *continuité de la chaîne d'activité et de données*, non la *continuité de la chaîne contractuelle*.
- (b) Le passage d'une sous-catégorie de niveau 2, rattachée à la gestion de l'externalisation, à une catégorie de niveau 1 autonome signifie, pour la gouvernance interne d'un établissement, que le risque tiers cesse d'être traité comme une simple composante du risque d'externalisation pour recevoir un traitement de gestion des risques à part entière. Concrètement, cela implique généralement un **reporting dédié** au risque tiers plutôt qu'un reporting agrégé et noyé dans celui de l'externalisation, une **appétence au risque spécifique** (des seuils et limites propres au risque tiers, distincts de ceux fixés pour l'externalisation en général), et des **indicateurs propres** (par exemple un décompte des relations de quatrième et cinquième parties identifiées, ou un taux de couverture des évaluations de risque tiers) qui n'auraient pas nécessairement d'équivalent dans un reporting d'externalisation générique. Ce changement de statut taxonomique traduit, en somme, une visibilité et une gouvernance dédiées, à la mesure de l'importance et de la spécificité désormais reconnues à ce risque.
- (c) Les cinq étapes, dans l'ordre exact du cours, sont : (1) **la décision de modèle d'affaires** — déterminer si le recours à un tiers est justifié et quel type de relation est recherché ; (2) **l'évaluation, la notation du risque et la diligence raisonnable** — qualifier le tiers pressenti et son niveau de risque avant tout engagement ; (3) **les contrats et accords de niveau de service (SLA)** — formaliser les obligations réciproques et les normes de performance attendues ; (4) **le suivi continu** — surveiller la relation dans la durée, en fonction du niveau de risque attribué ; (5) **la remédiation ou la résiliation** — agir lorsque la relation se dégrade, jusqu'à y mettre fin si nécessaire.
- (d) Un tel établissement n'aurait **pas** mis en œuvre une gestion du risque tiers conforme au cadre du cours. Le cours est explicite : la gestion du risque tiers « ne s'arrête jamais à la signature du contrat », et « la phase de suivi continu et la possibilité de remédiation ou de résiliation font partie intégrante du dispositif, au même titre que la sélection initiale ». Exécuter scrupuleusement les trois premières étapes sans les deux dernières reviendrait précisément à traiter le cycle comme « une liste de contrôle ponctuelle » plutôt que comme un cycle continu : cela reviendrait à s'assurer que le tiers est correctement sélectionné et contractualisé au jour 1, sans jamais vérifier par la suite que la relation reste conforme au niveau de risque attribué, ni disposer d'un mécanisme pour agir si elle se dégrade — exactement le type de lacune que le cas Morgan Stanley (exercice 3) illustre a posteriori.

Corrigé de l'exercice 2 — Étude de cas Capital One : migration cloud et diligence préalable

- (a) En juillet 2019, Capital One a révélé une violation de données ayant exposé les informations personnelles d'environ **100 millions de personnes** aux États-Unis. L'attaquante était une **ancienne employée d'Amazon Web Services (AWS)**, qui a exploité une **mauvaise configuration d'un pare-feu applicatif web (WAF)** hébergé sur l'infrastructure cloud de Capital One pour

mener une attaque de type **Server-Side Request Forgery (SSRF)**, lui permettant d'accéder à des données stockées sur AWS. Elle a été arrêtée peu après les faits.

- (b) La distinction est celle entre sanctionner un *événement* (l'attaque SSRF elle-même, ses modalités techniques précises, son auteure) et sanctionner un *manquement de processus antérieur et indépendant de cet événement* (l'insuffisance de l'évaluation des risques et des contrôles compensatoires avant la migration). Selon cette logique, le montant de la sanction aurait pu être identique même si l'attaque SSRF n'avait jamais eu lieu, dès lors que l'insuffisance de l'évaluation des risques préalable à la migration — la cause retenue par l'OCC — aurait existé de toute façon, indépendamment de la survenance ou non d'une attaque effective : ce n'est pas la matérialisation du risque qui est sanctionnée, mais l'absence du dispositif qui aurait dû le prévenir ou en limiter la portée, un dispositif dont la défaillance est constatable sans attendre qu'un incident la révèle.
- (c) La réputation et la compétence technique d'AWS renseignent sur la fiabilité de l'infrastructure *générique* fournie par ce tiers, mais ne disent rien de la façon dont *Capital One elle-même* a configuré et exploité cette infrastructure pour ses propres besoins. Le cours l'énonce précisément : « recourir à un prestataire technologique de premier plan comme AWS ne dispense pas l'établissement d'évaluer et de maîtriser lui-même les risques de configuration et d'architecture de son propre environnement hébergé », car la faille exploitée — une mauvaise configuration du WAF — relevait des choix de configuration propres à Capital One sur l'infrastructure AWS, non d'une défaillance intrinsèque à AWS. La compétence du tiers porte sur la plateforme qu'il met à disposition ; la diligence raisonnable du client porte sur l'usage que celui-ci en fait — deux objets distincts, de sorte que l'excellence du premier ne peut jamais se substituer à l'exercice du second.
- (d) La défaillance de Capital One se rattache le plus directement à l'**étape 2** du cycle — « l'évaluation, la notation du risque et la diligence raisonnable ». L'OCC a en effet motivé sa sanction par l'insuffisance des « processus d'évaluation des risques mis en œuvre **avant** la migration vers l'infrastructure cloud publique », un moment qui précède structurellement l'entrée en relation effective (la migration elle-même) et non un manquement survenu *pendant* l'exécution de la relation (ce qui relèverait plutôt de l'étape 4, le suivi continu). L'insuffisance porte ainsi sur la préparation de la décision d'externaliser vers le cloud — « la banque n'avait pas correctement évalué les risques inhérents à ce type d'architecture » — et non sur une surveillance déficiente d'une relation déjà en cours.

Corrigé de l'exercice 3 — Étude de cas Morgan Stanley : répétition et angle mort du décommissionnement

- (a) Morgan Stanley a été sanctionnée par l'OCC à hauteur de **60 millions USD** pour des défaillances dans la gestion et la surveillance des risques liés à ses tiers. Les deux incidents sont survenus à l'occasion du **décommissionnement de serveurs de gestion de patrimoine**, une première fois en **2016**, puis à nouveau en **2019**. Dans les deux cas, les processus de retrait des équipements n'ont pas garanti l'**effacement sécurisé ou la destruction appropriée des données clients** qui y étaient stockées.
- (b) Un incident isolé et unique en 2019, sans précédent en 2016, aurait pu être interprété comme une défaillance ponctuelle d'un contrôle donné — regrettable, mais localisée dans le temps. La répétition, en revanche, révèle que l'établissement disposait déjà, dès 2016, d'un signal clair sur la fragilité de ses procédures de décommissionnement, et que ce signal n'a pas été traité : le second incident ne prouve donc pas seulement l'existence d'une faille technique, mais l'**absence de correction** de cette faille après qu'elle a été révélée une première fois. C'est précisément ce que le cours désigne comme « un manquement à la surveillance continue, pas seulement à un contrôle ponctuel » : la faute ne réside plus dans le contrôle initial manqué, mais dans l'incapacité du dispositif de suivi à garantir que la leçon du premier incident a effectivement été intégrée.
- (c) Structurellement, une organisation consacre spontanément moins d'attention à la fin d'une relation tierce qu'à son commencement pour plusieurs raisons convergentes : à l'entrée en relation, l'attention organisationnelle est mobilisée par la décision elle-même (sélection du prestataire, négociation contractuelle, mise en service), qui engage l'avenir et justifie un examen

soigné ; à la sortie, en revanche, l'attention s'est déjà largement déplacée vers la relation *suivante* (le nouveau prestataire, la nouvelle architecture), reléguant le retrait de l'ancien actif ou de l'ancienne relation au rang de tâche résiduelle et administrative. De plus, le matériel en fin de vie change de statut au regard de la vigilance qu'on lui porte : un serveur en production est activement surveillé et sécurisé, tandis qu'un serveur « décommissionné » est déjà mentalement classé comme hors périmètre actif, alors même qu'il continue, tant qu'il n'a pas été effacé ou détruit, de porter des données sensibles bien réelles.

- (d) La défaillance de Capital One relève de l'étape 2 du cycle (évaluation et diligence raisonnable *avant* l'engagement dans l'architecture cloud), tandis que celle de Morgan Stanley relève des étapes 4 et 5 (suivi continu et remédiation, à l'occasion de la *sortie* d'un actif ou d'une relation). Ce sont donc bien deux moments distincts du cycle : l'un en amont de l'engagement, l'autre en aval, à la fin de vie d'un actif. Ensemble, ces deux cas illustrent précisément l'affirmation de la synthèse selon laquelle « les sanctions les plus lourdes sanctionnent moins l'incident lui-même que l'absence de dispositif de contrôle robuste en amont » : dans les deux cas, ce n'est pas la matérialisation ponctuelle du risque (l'attaque SSRF, la récupération de données sur un serveur retiré) qui est sanctionnée en tant que telle, mais l'absence, à des moments différents du cycle de vie de la relation tierce, d'un dispositif de contrôle qui aurait dû être en place — que ce moment soit celui de l'entrée dans la relation ou celui de sa sortie.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — Le risque tiers à la lumière des quatre chapitres précédents

- (a) La définition de ce chapitre ne fait effectivement que systématiser et prolonger d'un cran ce que le chapitre 11 mentionnait déjà en germe : la parenthèse du chapitre 11 — « le « risque de quatrième partie » » — introduisait la notion sans lui donner de cadre propre, comme une simple précision apportée au troisième axe de la diligence raisonnable envers un prestataire. Ce chapitre reprend cette même notion mais l'intègre dans une chaîne complète et nommée à trois niveaux (tiers, quatrième partie, cinquième partie), avec l'affirmation explicite d'une exposition qui « reste » même « sans relation contractuelle directe » — une généralisation directe de la logique du chapitre 11 à un niveau supplémentaire de la chaîne de sous-traitance. Ce que ce chapitre ajoute, au-delà de cette généralisation, est un **cadre d'analyse complet** que le chapitre 11 ne fournissait pas : un cycle de vie structuré en cinq étapes explicites (décision de modèle d'affaires, évaluation et diligence raisonnable, contrats et SLA, suivi continu, remédiation ou résiliation), un statut taxonomique propre (catégorie de niveau 1 autonome selon l'ORX plutôt que sous-catégorie de l'externalisation), et deux **illustrations concrètes et chiffrées** (Capital One, 80 millions USD ; Morgan Stanley, 60 millions USD) qui donnent un poids empirique à une notion que le chapitre 11 ne faisait qu'esquisser en une parenthèse.
- (b) Les deux cas — sous-traitants non vérifiés chez USAA, architecture cloud non évaluée chez Capital One — relèvent bien de la même étape défaillante du cycle de ce chapitre : **l'étape 2, évaluation, notation du risque et diligence raisonnable**, en amont de l'engagement. Chez USAA, la défaillance porte sur l'absence de vérification des qualifications de sous-traitants engagés pour combler un déficit d'effectifs en conformité LCB-FT ; chez Capital One, elle porte sur l'absence d'évaluation des risques inhérents à une architecture cloud avant sa mise en service. Dans les deux cas, c'est le même maillon du cycle — l'examen préalable à l'engagement — qui a fait défaut, quelle que soit la nature très différente de l'activité concernée (conformité réglementaire humaine contre infrastructure technique). L'écart de sanction (140 millions USD contre 80 millions USD) ne tient toutefois pas à une différence de *nature* de la défaillance — toutes deux relèvent de la même étape 2 — mais plutôt à une différence d'*ampleur et de portée* du manquement constaté : le chapitre 10 précise que la sanction USAA portait sur l'ensemble d'un programme de conformité « significativement sous-effectif » et doté d'un système de surveillance débordé (un arriéré de « 90 000 alertes et 6 900 dossiers non examinés »), c'est-à-dire une défaillance cumulée touchant plusieurs piliers du dispositif sur plusieurs années, alors

que la sanction Capital One porte plus étroitement sur l'insuffisance d'une évaluation de risque circonscrite à une migration technique donnée.

- (c) L'exigence du chapitre 9 d'une évaluation périodique de l'effectivité du dispositif de surveillance, portée par l'audit interne comme troisième ligne de défense, est précisément le mécanisme dont l'absence a permis au second incident Morgan Stanley de se reproduire à l'identique : si un audit interne avait, entre 2016 et 2019, vérifié que les procédures de décommissionnement révisées à la suite du premier incident étaient effectivement appliquées — exactement le rôle que le chapitre 9 attribue à l'audit interne pour le système de surveillance ML/FT, « s'assurer qu'il est utilisé effectivement par les première et deuxième lignes de défense » —, l'absence de correction réelle des procédures aurait vraisemblablement été détectée avant qu'un second décommissionnement mal maîtrisé ne survienne. La logique de « suivi continu » (étape 4 du cycle de ce chapitre) rejoint ainsi directement l'exigence du chapitre 9 : dans les deux cas, il ne suffit pas qu'un dispositif de contrôle existe formellement (des procédures de décommissionnement écrites, un système de surveillance informatisé installé) ; encore faut-il qu'une vérification périodique et indépendante — un suivi continu, un audit interne récurrent — confirme que ce dispositif reste effectivement mis en œuvre dans la durée, pour un objet différent (le décommissionnement matériel contre la surveillance transactionnelle) mais selon un même principe de contrôle répété plutôt que ponctuel.
- (d) La leçon d'Equifax se transpose directement au cas Capital One si l'on considère qu'un établissement doit appliquer à ses actifs hébergés chez un tiers la même rigueur d'inventaire et d'évaluation de configuration qu'à ses actifs internes : chez Equifax, l'absence d'inventaire exhaustif des actifs *internes* a empêché de localiser et corriger une vulnérabilité connue (Apache Struts) dans le délai requis ; chez Capital One, une logique symétrique s'applique à un actif *externe* — l'environnement hébergé sur AWS — dont la configuration (le WAF mal paramétré) n'a pas été correctement évaluée avant sa mise en service, comme l'aurait révélé un inventaire et une cartographie rigoureuse des configurations de cet environnement. Ce chapitre généralise ainsi, au cas particulier de l'infrastructure tierce, une exigence de maîtrise des actifs que le chapitre 8 avait établie pour le seul périmètre interne de l'établissement : la responsabilité de savoir précisément ce que l'on possède, où cela se trouve, et comment cela est configuré, ne s'arrête pas à la frontière juridique de la propriété de l'infrastructure — « la compétence du tiers ne remplace pas la diligence raisonnable de son client » — mais s'étend, selon ce chapitre, à tout actif dont l'établissement dépend fonctionnellement, qu'il en soit propriétaire ou qu'il le loue à un tiers.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — La chaîne tiers, quatrième partie, cinquième partie : exposition en cascade, chiffré

On a quatre activités : Hébergement cloud (Tiers A, 2 400 k€, 45 % vers le 4^e, 30 % de ce montant vers le 5^e), Support informatique (Tiers B, 1 600 k€, 65 %, 40 %), Traitement des données clients (Tiers C, 1 000 k€, 25 %, 20 %), Sécurité physique (Tiers D, 500 k€, 0 %).

- (a) Montant sous-traité au 4^e et montant conservé directement par le tiers, activité par activité : Hébergement cloud, $2\,400 \times 0,45 = 1\,080$ k€ vers le 4^e, soit $2\,400 - 1\,080 = 1\,320$ k€ conservés par le tiers A. Support informatique, $1\,600 \times 0,65 = 1\,040$ k€ vers le 4^e, soit $1\,600 - 1\,040 = 560$ k€ conservés par le tiers B. Traitement des données clients, $1\,000 \times 0,25 = 250$ k€ vers le 4^e, soit $1\,000 - 250 = 750$ k€ conservés par le tiers C. Sécurité physique, $500 \times 0 = 0$ k€ vers le 4^e, soit 500 k€ intégralement conservés par le tiers D. Le montant total confié pour l'ensemble des quatre activités est $2\,400 + 1\,600 + 1\,000 + 500 = 5\,500$ k€.
- (b) Montant sous-traité par le 4^e au 5^e, et montant conservé directement par le 4^e : Hébergement cloud, $1\,080 \times 0,30 = 324$ k€ vers le 5^e, soit $1\,080 - 324 = 756$ k€ conservés par le 4^e. Support informatique, $1\,040 \times 0,40 = 416$ k€ vers le 5^e, soit $1\,040 - 416 = 624$ k€ conservés par le 4^e. Traitement des données clients, $250 \times 0,20 = 50$ k€ vers le 5^e, soit $250 - 50 = 200$ k€

conservés par le 4^e. Sécurité physique : aucun montant au-delà du tiers, donc 0 k€ à chaque niveau supplémentaire. Sur l'ensemble du portefeuille, le montant total conservé directement par les tiers est $1\,320 + 560 + 750 + 500 = 3\,130$ k€, le montant total conservé directement par les quatrièmes parties est $756 + 624 + 200 + 0 = 1\,580$ k€, et le montant total atteignant la cinquième partie est $324 + 416 + 50 + 0 = 790$ k€. (Ces trois montants totalisent bien $3\,130 + 1\,580 + 790 = 5\,500$ k€, soit le montant total confié.)

- (c) La part du montant total qui dépasse le seul tiers direct est la somme de ce qui est conservé par le 4^e et de ce qui atteint le 5^e, soit $1\,580 + 790 = 2\,370$ k€, rapportée aux 5 500 k€ du portefeuille : $2\,370/5\,500 = 43,09\%$ — près de 43 % de la dépense totale d'externalisation critique de cette banque échappe donc à tout lien contractuel direct avec elle. L'activité pour laquelle l'exposition à la cinquième partie est la plus élevée en valeur absolue est le **support informatique**, avec 416 k€ atteignant le 5^e niveau — devant l'hébergement cloud (324 k€), en raison de ses deux taux de sous-traitance successifs particulièrement élevés (65 % puis 40 %).
- (d) Pour le support informatique (montant total 1 600 k€; exposition tiers direct 560 k€, 4^e direct 624 k€, 5^e 416 k€), avec des probabilités d'incident de 2 % (tiers), 5 % (4^e) et 9 % (5^e), et une sévérité de 20 % de la valeur exposée en cas d'incident : la perte attendue au niveau du tiers est $0,02 \times 0,20 \times 560 = 2,24$ k€; au niveau de la quatrième partie, $0,05 \times 0,20 \times 624 = 6,24$ k€; au niveau de la cinquième partie, $0,09 \times 0,20 \times 416 = 7,488$ k€. La perte attendue totale de cette activité est $2,24 + 6,24 + 7,488 = 15,968$ k€ — soit plus de la moitié de cette perte attendue (7,488 k€ sur 15,968 k€) qui provient du seul niveau de la cinquième partie, la portion la plus éloignée de tout contrôle contractuel direct, en dépit de son montant exposé (416 k€) inférieur à celui du tiers direct ou de la quatrième partie. La probabilité qu'au moins un incident survienne quelque part dans la chaîne, sous hypothèse d'indépendance, est $1 - (1 - 0,02)(1 - 0,05)(1 - 0,09) = 1 - 0,98 \times 0,95 \times 0,91 = 1 - 0,84721 = 15,279\%$, à comparer à la seule probabilité d'incident chez le tiers direct de 2 % : un écart de $15,279 - 2 = 13,279$ points de pourcentage, qui mesure précisément l'ampleur du risque supplémentaire auquel la banque reste exposée du seul fait de l'existence de la chaîne de sous-traitance en aval du tiers, alors même qu'elle n'a de lien contractuel qu'avec ce dernier.

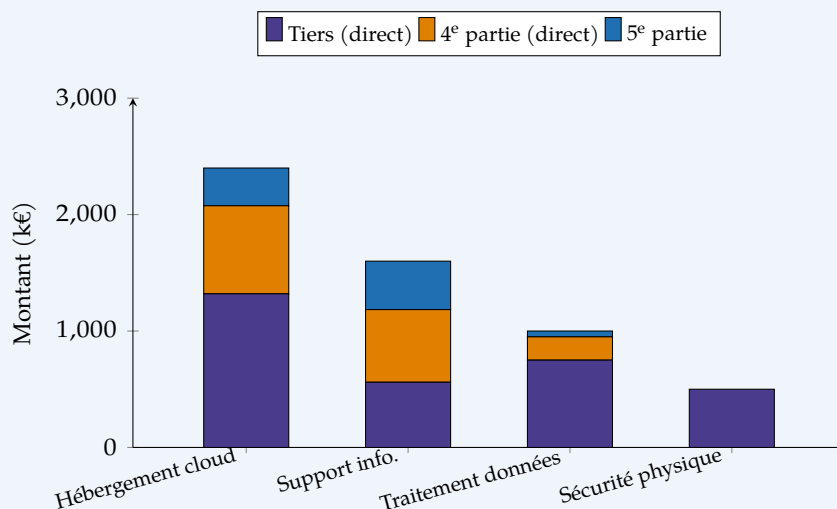


FIG. 1 : Décomposition du montant confié par activité entre tiers direct (bleu), quatrième partie (orange) et cinquième partie (vert) — exercice 5.

Corrigé de l'exercice 6 — Diligence préalable et effacement sécurisé : le coût attendu de sauter une étape

- (a) Sans évaluation préalable, le coût attendu de la violation est $0,12 \times 45\,000\,000 = 5\,400\,000$ \$. Avec évaluation préalable, il devient $0,02 \times 45\,000\,000 = 900\,000$ \$. La réduction brute du coût attendu est $5\,400\,000 - 900\,000 = 4\,500\,000$ \$, et le gain net, une fois déduit le coût de l'évaluation de 1 800 000 \$, est $4\,500\,000 - 1\,800\,000 = 2\,700\,000$ \$.

- (b) Le ratio bénéfice/coût de l'investissement est $4\,500\,000 / 1\,800\,000 = 2,50$: chaque dollar investi dans l'évaluation préalable rapporte, en moyenne, 2,50 dollars de réduction du coût attendu de violation. Ce ratio est parfaitement cohérent avec la logique de la sanction de l'OCC contre Capital One : le régulateur a précisément motivé son amende de 80 millions USD par l'« insuffisance des processus d'évaluation des risques mis en œuvre **avant** la migration », et non par l'attaque elle-même — une façon réglementaire de dire que le coût de cette évaluation préalable était, par construction, très inférieur au coût attendu de son omission, exactement ce que ce calcul de ratio bénéfice/coût de 2,50 vient chiffrer explicitement.
- (c) Le coût total de l'effacement sécurisé pour les 4 000 serveurs est $4\,000 \times 120 = 480\,000$ \$. Le coût attendu d'un premier incident en l'absence d'effacement sécurisé est $0,18 \times 8\,000\,000 = 1\,440\,000$ \$. L'écart entre les deux est $1\,440\,000 - 480\,000 = 960\,000$ \$: l'investissement préalable dans l'effacement sécurisé est **largement justifié** au regard de ce seul écart, son coût ne représentant qu'un tiers environ ($480\,000 / 1\,440\,000 = 33,3\%$) du coût attendu de l'incident qu'il permet d'éviter.
- (d) En voie « sans remédiation », le coût attendu du second incident est $0,50 \times 12\,000\,000 = 6\,000\,000$ \$. En voie « avec remédiation », le coût attendu est le coût de la remédiation plus le coût attendu résiduel du second incident : $400\,000 + 0,04 \times 12\,000\,000 = 400\,000 + 480\,000 = 880\,000$ \$. La voie « avec remédiation » minimise nettement le coût attendu, pour une économie de $6\,000\,000 - 880\,000 = 5\,120\,000$ \$ — un rapport de $6\,000\,000 / 880\,000 = 6,82$ fois moins coûteux en espérance. Ce résultat chiffre précisément la logique du cours selon laquelle la répétition d'un incident de décommissionnement, comme chez Morgan Stanley, aggrave la faute aux yeux du régulateur (« la preuve que les enseignements du premier incident n'avaient pas été tirés ») : ne pas remédier après un premier incident n'est donc pas seulement une faute de gouvernance, c'est aussi, comme le montre ce calcul, une décision qui maximise le coût attendu pour la banque elle-même.

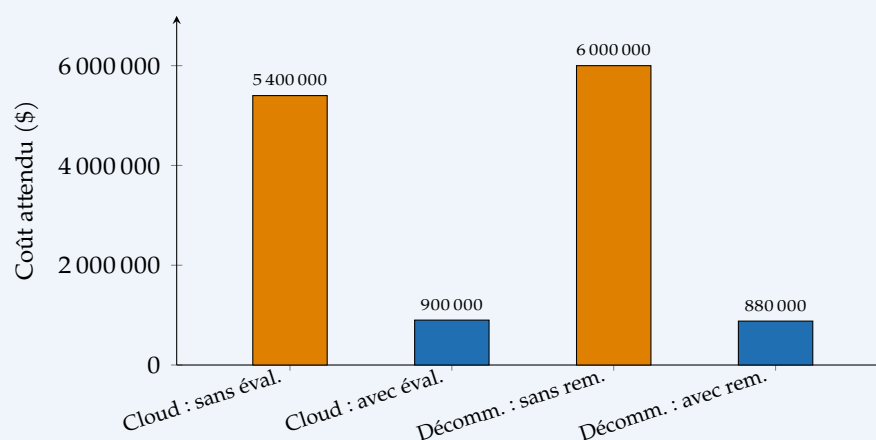


FIG. 2 : Coût attendu sans dispositif préalable (orange : évaluation cloud non réalisée, remédiation non engagée) contre coût attendu avec dispositif préalable (bleu) — exercice 6.